Nätverkssäkerhet

Föreläsning 1 – Kursintroduktion & introduktion till nätverkssäkerhet

Kursintro (från Kurs-PM)

Lärandemål

- visa förståelse för **nätverksutrustning** och dess funktion för **säkerhet** i nätverk
- visa förståelse för **centrala begrepp** inom **nätverkssäkerhet** och **informationssäkerhet**
- visa färdighet i **planering och uppsättning** av **säkerhetslösningar** för små och stora nätverk
- visa insikt i **etiska aspekter** inom **nätverksteknik** med avseende på **loggning, avlyssning, penetrationstestning** och liknande
- visa förmåga till ett **säkerhetsmedvetet förhållningssätt** vid **planering, design och implementation** av lokala nätverk

Innehåll

- Allmän introduktion till nätverkssäkerhet och koncept
- AAA
- Säkerhet i lokala nätverk (L2)
- Säkerhet i routrar
- Brandväggar och IDS/IPS
- Kryptering och VPN

Kursmaterial

- **Kurslitteratur**
  - Webbmaterial på NetAcad (notera plattformsbyte)
- **Laborationer**
  - Labb-PM (Canvas)
  - Labbhäfte som referenslitteratur
- **Övrigt (Canvas)**
  - Föreläsningsunderlag och övrigt material

Lärmoment

- **Föreläsningar (2-4 h/v)**
  - Tisdagar (2h), videoinspelningar (1-3h)
- **Laborationer (4 h/v)**
  - Måndag förmiddag/eftermiddag (förutom denna vecka)
  - Arbete i grupp (beror på labb)
- **Självstudier (ca. 10-14 h/v)**
  - Läsa kurslitteratur, göra kapiteltester
  - Egna laborationer
  - Övrigt material (YouTube, CBT-nuggets, etc.)

Examinerande moment

- **Tentamen** (3 hp)
  - Digital tentamen (100p)
    - **U** = <60p, **3** = 60p, **4** = 75p, **5** = 90p
    - Sätter betyget på kursen
- **Laborationer** (4,5 hp)
  - U/G

Laborationer

- Laboration 1 – **Introduktionslabb** (2 veckor)
- Laboration 2 – **Brandväggar**
  - Laboration 2.1 – ZPF, VRF & FortiGate
  - ~~Laboration 2.2 – VDOM~~
- Laboration 3 – **IDS & IPS**
- Laboration 4 – **LAN- och endpoint-säkerhet**
- Laboration 5 – **VPN & kryptografi**
- Laboration 6 – **Case study**

Frivilliga moment

- Duggor (start nästa vecka)
  - Tisdagar kl. 9

Feedback från förra omgången

- Helhetsbetyg: **6,3** av 7
- Studenter är överlag nöjda med materialet och den röda tråden
- Vissa hinner inte färdigt med laboration under labbpass, den parallella kursen tar dessutom väldigt mycket tid
  - Virtualisering är flyttad, och labbar optimerade (innan sommaren)
- Rättning av laborationer tar för lång tid
  - Ska försöka bättra mig!

Kontinuerlig feedback

- **Era åsikter**
  - Prata med mig under kursens gång!
  - Halvtidsutvärdering
  - Kursutvärdering
- **Era kunskaper**
  - Quiz varje föreläsning
  - Duggor varje vecka

Planering

- Ska försöka få in gästföreläsningar från:
  - Fortinet (sponsrar även med utrustning)
  - Dizparc
  - Orange Cyberdefense
  - Atea
  - Cygate

Vecka	Dag	Moment
35	Mån	**Föreläsning** – Kursintroduktion & introduktion till nätverkssäkerhet
	-	**Videoföreläsningar** – Säkra upp enheter & AAA
	Mån /Tis	**Laboration 1**
36	Mån	**Forts. Laboration 1**
	Tis	**Dugga 1** (09.00)
	Fre	**Föreläsning –** Introduktion till brandväggar
37	Mån	**Laboration 2**
	Tis	**Dugga 2** (09.00)
	Tis	**Föreläsning** – IDS/IPS
38	Mån	**Laboration 3**
	Tis	**Dugga 3** (09.00)
	Tis	**Föreläsning** – LAN- och endpoint-säkerhet & **NFK-information**
39	Mån	**Laboration 4**
	Tis	**Dugga 4** (09.00)
	-	**Videoföreläsning** – Kryptografi
	Tor	**Föreläsning** – VPN
40	Mån	**Laboration 5**
	Tis	**Dugga 5** (09.00)
	Tis	**Föreläsning** – Extrapass
41	Ons	**Laboration 6 & Redovisningar av Laboration 6**
42	-	**Tentavecka**

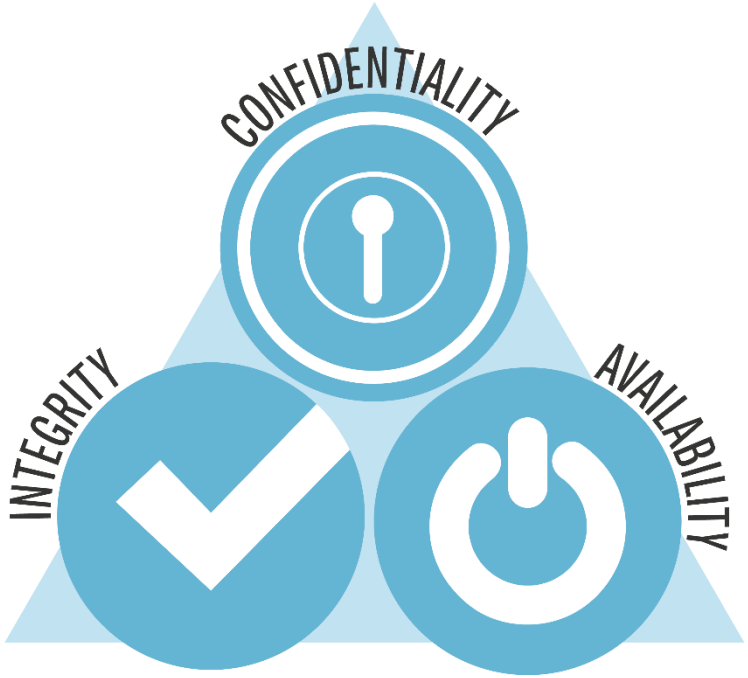
Nätverkssäkerhet

Informationssäkerhet

- *"Information security […] is* ***the practice of preventing unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction of information****. […] Information security's* ***primary focus is the balanced protection of the confidentiality, integrity and availability of data*** *[…] while maintaining a focus on efficient policy implementation, all without hampering organization productivity" (Wikipedia)*
- Flera olika modeller och standarder:
  - CIA
  - Skyddsåtgärder likt AAA, TFI/PPT, etc.
  - ISO 27000-serien

CIA

- CIA är en av de vanligaste principerna när man pratar om **informationssäkerhet**:
  - Confidentiality (**Konfidentialitet**)
  - Integrity (**Riktighet**)
  - Availability (**Tillgänglighet**)
- Vad innebär detta rent praktiskt?



Ett utav de mest digitala länderna…

TABLE 1: TOP 10 PERFORMERS IN NRI 2020

			PILLARS			
Country	NRI Rank	NRI Score	Technology	People	Governance	Impact
Sweden	1	82.75	2	4	4	3
Denmark	2	82.19	5	1	2	5
Singapore	3	81.39	10	5	13	1
Netherlands	4	81.37	3	9	3	4
Switzerland	5	80.41	1	13	10	2
Finland	6	80.16	9	3	5	9
Norway	7	79.39	11	8	1	6
United States	8	78.91	4	7	8	14
Germany	9	77.48	7	12	12	7
United Kingdom	10	76.27	8	14	14	10

Källa: https://networkreadinessindex.org/wp-content/uploads/2020/11/NRI-2020-V8_28-11-2020.pdf

…men inte bäst på cybersäkerhet

- Global Cybersecurity Index (GCI) 2020
- Plats 26 av 182

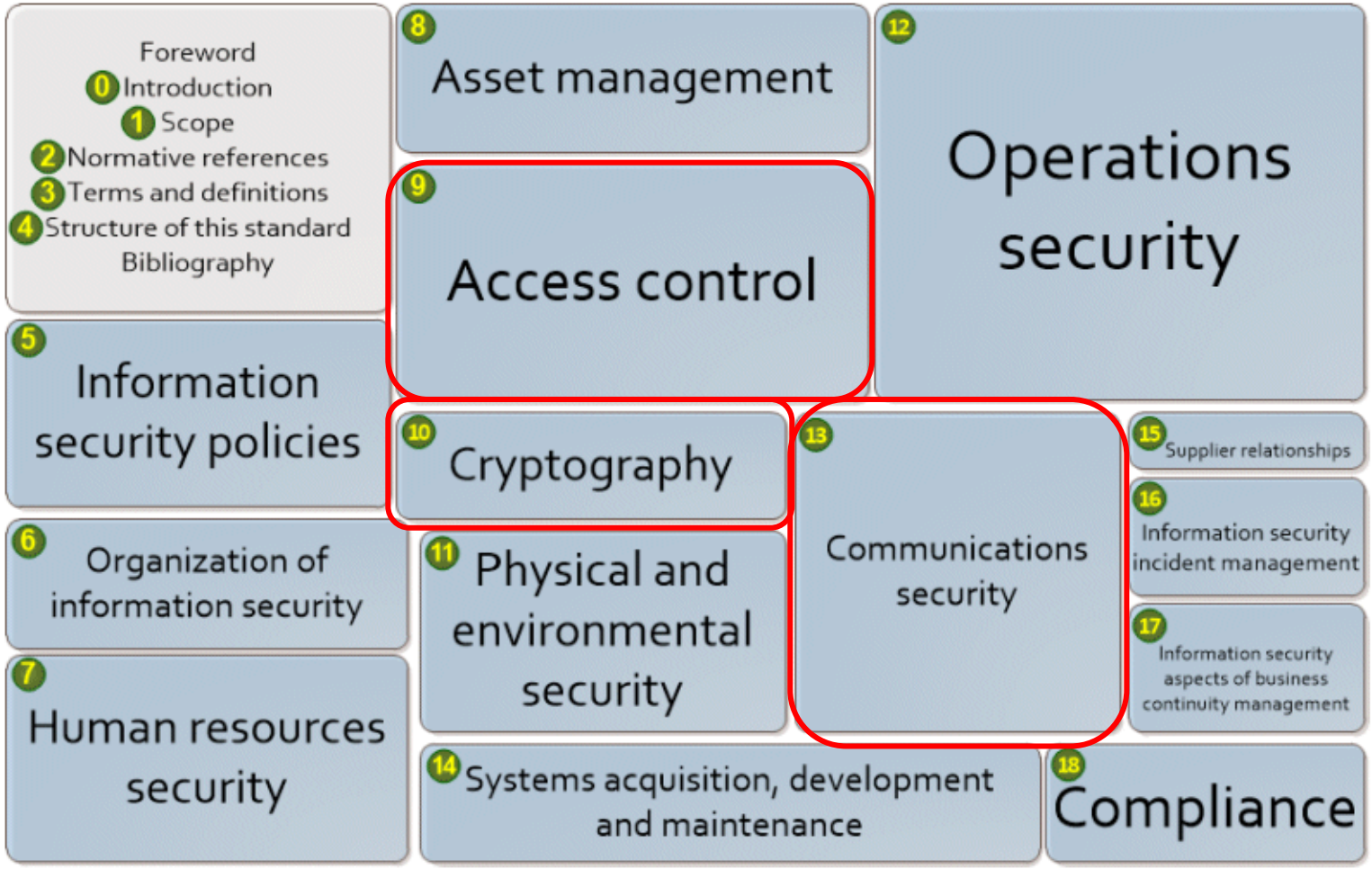
Country Name	Score	Rank
United States of America**	100	1
United Kingdom	99.54	2
Saudi Arabia	99.54	2
Estonia	99.48	3
Korea (Rep. of)	98.52	4
Singapore	98.52	4
Spain	98.52	4
Russian Federation	98.06	5
United Arab Emirates	98.06	5
Malaysia	98.06	5
Lithuania	97.93	6
Japan	97.82	7
Canada**	97.67	8
France	97.6	9
India	97.5	10
Turkey	97.49	11
Australia	97.47	12
Luxembourg	97.41	13
Germany	97.41	13
Portugal	97.32	14
Latvia	97.28	15
Netherlands**	97.05	16
Norway**	96.89	17
Mauritius	96.89	17
Brazil	96.6	18
Belgium	96.25	19
Italy	96.13	20
Oman	96.04	21
Finland	95.78	22
Egypt	95.48	23
Indonesia	94.88	24
Viet Nam	94.59	25
Sweden	94.55	26

Källa: https://www.itu.int/epublications/publication/global-cybersecurity-index-2020/en/

ISO/IEC 27000-serien

- ISO har tillsammans med IEC beskrivit 14 olika domäner för arbetet med informationssäkerhet (**ISO 27002**)

- (Enligt Cisco är allt nätverkssäkerhet)

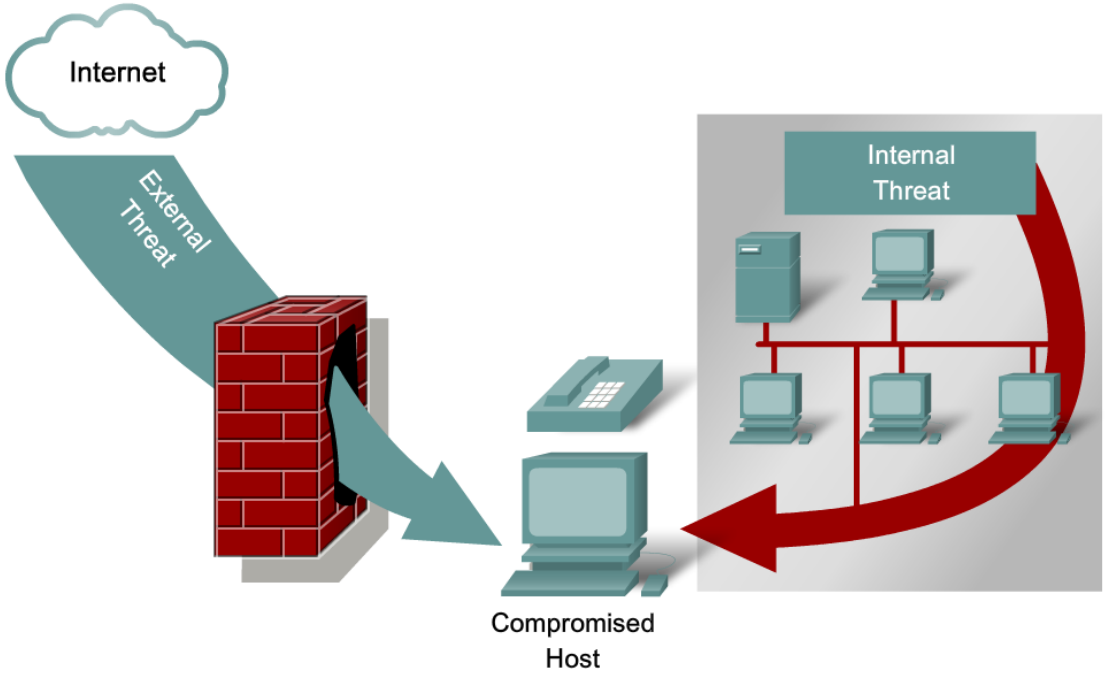


Källa: http://www.iso27001security.com/html/27002.html

Hot

- Naturliga eller miljömässiga hot
- Oavsiktliga hot
- Avsiktliga hot

Externa och interna hot



- **Hot från utsidan (externa)**
  - Hackers, malware
  - Andra organisationer (industrispionage)
  - DoS och DDoS
- **Hot från insidan (interna)**
  - Anställda
  - Gäster
  - **Både avsiktliga och oavsiktliga handlingar**
- Från ett nätverkssäkerhetsperspektiv måste man skydda båda!
- Interna ”attacker” genererar ofta större skada, och står för den största andelen

Hotaktörer

- Främmande makt
  - State-sponsored
- Kriminella
  - Cyber Criminal
  - Vulnerability brokers
- Aktivister
  - Hacktivists
- Skojare och ”script kiddies”
- Skillnader: Vad är målet? Hur sker attacken?

Attacker

- Ransomware
- Stöld av information
- Överbelastningsattacker
- Supply chain-attacker
- Social engineering

SVERIGE

Hackargruppen Akira hotar att läcka svenska data

Domstolsverkets webbplats utsatt för överbelastningsattack

Coop och hackerattacken

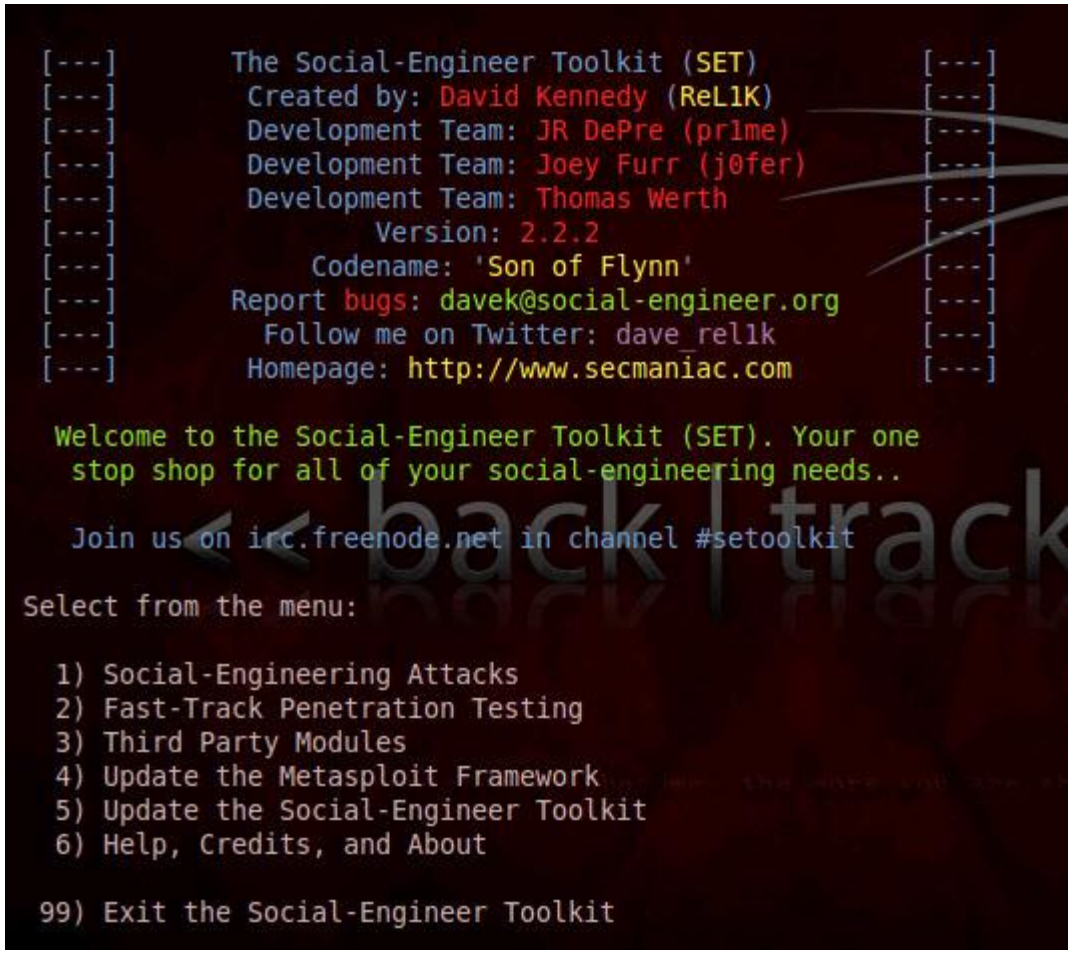
Coop-butiker tvingas hålla stängt – it-attack bakom

Låtsades vara vd – fick anställd att föra över 150 miljoner

1:38 min Min sida Dela

Verktyg för attacker/pentesting 1 (2)

- **Password crackers**
  - L0phtCrack, John the Ripper osv.
- **Wireless hacking tools**
  - Aircrack-ng
- **Network Scanning tools**
  - Nmap
- **Packet Crafting Tools**
  - Netcat, Nping
- **Packet Sniffers**
  - Wireshark, Tcpdump



Verktyg för attacker/pentesting 2 (2)

- **Forensic tools**
  - Autopsy
- **Hacking Operating Systems**
  - Kali Linux
- **Vulnerability Scanners**
  - Nessus, OpenVAS (gvm)
- **Vulnerability Exploitation Tools**
  - Metasploit

Sårbarheter

- Administrativa sårbarheter
  - Dåliga rutiner, för höga behörigheter, avsaknad av krav på exempelvis kryptering
- Tekniska sårbarheter
  - Gammal mjukvara fylld med sårbarheter
  - Felkonfigurerad mjukvara
  - Egentligen beror ovanstående på mänskliga faktorer
- Mänskliga sårbarheter
  - Stulna konton, svaga lösenord
  - Nätfiske (**phishing**) eller annat lurendrejeri

Dålig phishing

Från: info=postnord-sverige.com@ckmail4.com på uppdrag av PostNord <info@postnord-sverige.com>
Skickat: söndag, december 30, 2018 7:36 em
Till: [redacted]
Ämne: [redacted] Paketet har försökt levereras till dig.

View in browser

postnord

Ditt paket vänter på dig
Ditt paket med spåringsnummer #SE-SAM32013. Paket har forsökt levereras till dig.

Vi har därfor infört en avgift på 5 kronor.
När det är betalt får du ett formulär som måste överlämnas till posten.

Om paketet ine kommer at tas emot inom 14 arbejdsdagar, har PostNord rätt att kräva erstättning från dig.

Du kan hitta om förfarandet och villkoren för paketet lagring i närmaste koontor.

Betal frakt

https://www.skadligkod.se/scam/falska-sms-fran-postnord-slutar-i-manadsprenumeration/

Bra phishing (spear phishing)

Receipt of Your Payment from Rebecca Lindstrom (rebeccalindstrom5@gmail.com)

S service@paypal.co.uk
2018-02-19 19:13

Till: [redacted]

PayPal

19 FEB 2018 07:10:24 BST

Hello [redacted]

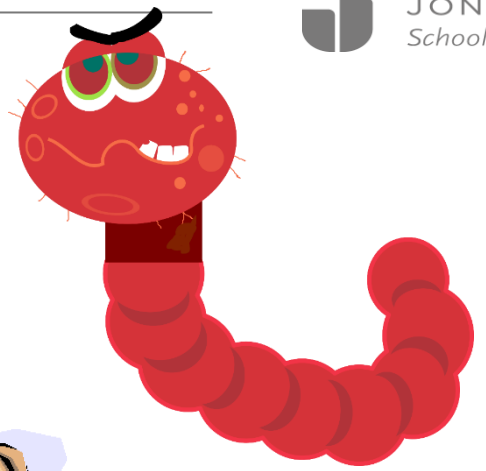
You received a payment of 5,800:00 SEK from Rebecca Lindstrom (rebeccalindstrom5@gmail.com) Thank you for using PayPal. You can now send any items. To see all the transaction details, log in to your PayPal account.

It may take some time for this transaction to appear in your account.

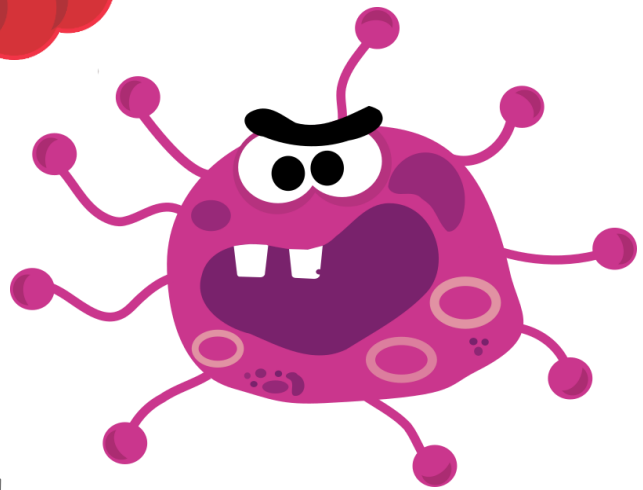
This PayPal Payment has been deducted from Rebecca Lindstrom account,but cannot be transfer into your account for now until we verify the shipment of the item as we have verify this PayPal payment.You have to go and ship out Rebecca Lindstrom merchandise within now and the next 48hrs,Get back to PayPal with the evidence of the shipment {shipment tracking number} for shipment verification.Once we verify the shipment to be genuine,the total sum of 5,800:00 SEK will show up in your account with immediate effect.This New measure is being taking due to some fraudulent sellers that do receive buyer's payment but will not ship out the merchandise that was paid for,and to protect both the buyer and the seller against the occurrence of fraudulent activities on the internet these days.

Seller Protection - Eligible

Malware (skadlig kod)



- **Malware** finns i många varianter:
  - Virus
  - Trojan
  - Worm
  - Ransomware
  - …och många fler



- Vi har gått igenom dessa innan, men läs in detta i boken!
- Finns olika definitioner och beskrivningar. I denna kurs utgår vi från boken, men var medvetna om att andra böcker kan beskriva det annorlunda

Wana Decrypt0r 2.0
Ooops, your files have been encrypted!
English
Payment will be raised on
5/16/2017 00:47:55
Time Left
02:23:57:37
Your files will be lost on
5/20/2017 00:47:55
Time Left
06:23:57:37
What Happened to My Computer?
Your important files are encrypted.
Many of your documents, photos, videos, databases and other files are no longer accessible because they have been encrypted. Maybe you are busy looking for a way to recover your files, but do not waste your time. Nobody can recover your files without our decryption service.
Can I Recover My Files?
Sure. We guarantee that you can recover all your files safely and easily. But you have not so enough time.
You can decrypt some of your files for free. Try now by clicking <Decrypt>.
But if you want to decrypt all your files, you need to pay.
You only have 3 days to submit the payment. After that the price will be doubled.
Also, if you don't pay in 7 days, you won't be able to recover your files forever.
We will have free events for users who are so poor that they couldn't pay in 6 months.
How Do I Pay?
Payment is accepted in Bitcoin only. For more information, click <About bitcoin>.
Please check the current price of Bitcoin and buy some bitcoins. For more information, click <How to buy bitcoins>.
And send the correct amount to the address specified in this window.
After your payment, click <Check Payment>. Best time to check: 9:00am - 11:00am
About bitcoin
How to buy bitcoins?
Contact Us
bitcoin
ACCEPTED HERE
Send $300 worth of bitcoin to this address:
12t9YDPgwueZ9NyMgw519p7AA8isjr6SMw
Copy
Check Payment
Decrypt

Lösensumma
$ 300

Skulle du betala?

```
C:\>type akira_readme.txt
Hi friends,

Whatever who you are and what your title is if you're reading this it means the internal infrastructure of your company
is fully or partially dead, all your backups - virtual, physical - everything that we managed to reach - are completely
removed. Moreover, we have taken a great amount of your corporate data prior to encryption.

Well, for now let's keep all the tears and resentment to ourselves and try to build a constructive dialogue. We're fully
 aware of what damage we caused by locking your internal sources. At the moment, you have to know:

1. Dealing with us you will save A LOT due to we are not interested in ruining your financially. We will study in depth
your finance, bank & income statements, your savings, investments etc. and present our reasonable demand to you. If you
have an active cyber insurance, let us know and we will guide you how to properly use it. Also, dragging out the negotia
tion process will lead to failing of a deal.
2. Paying us you save your TIME, MONEY, EFFORTS and be back on track within 24 hours approximately. Our decryptor works
properly on any files or systems, so you will be able to check it by requesting a test decryption service from the begin
ning of our conversation. If you decide to recover on your own, keep in mind that you can permanently lose access to som
e files or accidently corrupt them - in this case we won't be able to help.
3. The security report or the exclusive first-hand information that you will receive upon reaching an agreement is of a
great value, since NO full audit of your network will show you the vulnerabilities that we've managed to detect and used
 in order to get into, identify backup solutions and upload your data.
4. As for your data, if we fail to agree, we will try to sell personal information/trade secrets/databases/source codes
- generally speaking, everything that has a value on the darkmarket - to multiple threat actors at ones. Then all of thi
s will be published in our blog -
5. We're more than negotiable and will definitely find the way to settle this quickly and reach an agreement which will
satisfy both of us.

If you're indeed interested in our assistance and the services we provide you can reach out to us following simple instr
uctions:

1. Install TOR Browser to get access to our chat room - https://www.torproject.org/download/.
2. Paste this link -
3. Use this code -                    - to log into our chat.

Keep in mind that the faster you will get in touch, the less damage we cause.
```

https://akiral2iz6a7qgd3ayp3l6yub7xx2uep76idk3u2kollpj5z3z636bad.onion/

Lösensumma
2 % av årsomsättningen

Skulle du betala?

Kategorisering av nätverksattacker

- **Vilka tre kategorier finns det (enligt Cisco)?**
- **Reconnaissance attacks**
  - Samla information om ett nätverk
- **Access attacks**
  - Intrång in till låsta system och konton
  - **Social Engineering**
- **Denial of Service attacks**
  - Överbelastning eller andra metoder för att sänka ett nätverk eller en mjukvara

Reconnaissance Attacks

- Inkluderar bland annat:
  - WHOIS
  - Portskanning (har jag visat Shodan?)
  - Ping sweeps
  - Paketsniffning
- Exempel:
  1. Samla information om företaget via t.ex. Google
  2. Utför en ***ping-sweep*** mot nätverket
  3. Utför en ***portskanning*** mot nätverket
  4. Kör en ***Vulnerability Scanner*** mot nätverket, t.ex. *Nessus* eller *OpenVAS*
  5. **Access:** (Kör en ***Exploitation Tool*** mot en tjänst med svagheter, t.ex. via *Metasploit)*

Skydd mot Reconnaissance Attacks

- Kryptera och autentisera känslig trafik
  - SSH, inte Telnet
  - HTTPS, inte HTTP
  - **Och/eller:** OOB management
- Brandväggar och IDS/IPS kan till viss del skydda mot ping sweeps, portskanning och sårbarhetsskanning
- Katt- och råtta-lek mellan attackverktyg och skydd

Access Attacks

- **Access-attacker** handlar bland annat om att:
  - Få tag i hemlig data
  - Få tillgång till låsta system
  - Öka behörigheten/privilegierna i ett system
- Typer av attacker:
  - **Password attack** – Gissa, ordlisteattacker, brute force, rainbow tables
  - **Trust exploitation** - Utnyttja rättigheter du inte bör ha
  - **Man-in-the-middle** - Dirigera om trafiken så den går via en sniffande enhet
  - **Buffer overflow** – Utnyttja ledigt minne i ett program för att få in skadlig kod eller sänka nätverk/mjukvara

Metoder

- Fler typer:
  - **XSS**
  - **SQL injection**
  - **Social Engineering**
- **Skydd**:
  - Starka lösenord
  - *”Principle of minimum trust”*
  - Kryptering
  - Patchar

```
n;4123;Norra Hisingen, B►llsk►r;Satanistiskt initiativ;1
n;4152;Lundby, Br►mareg►rden, ►stra;Satanistiskt initiativ;1
n;4024;Lundby, Kvilleb►cken, S►dra;Satanistiskt initiativ;1
n;3035;►stra G►teborg, Kortedala, ►stra;Satanistiskt initiativ;1
n;7011;V►stra Hisingen, Biskopsg►rden, N;Satanistiskt initiativ;1
n;1021;Majorna-Linn►, Sandarne;Schizofrena autistpartiet;1
n;5093;Askim-Fr►lunda-H►gsbo, Kaver►s, S;"script"alert('l')"/script";1
n;4123;Norra Hisingen, B►llsk►r;SD = rasister;1
n;5091;Askim-Fr►lunda-H►gsbo, Kav►s;S.I;1
n;5091;Askim-Fr►lunda-H►gsbo, Kav►s;Sjukv►rdspartiet;1
n;5033;V►stra G►teborg, T►ngudden;Sl►seri ombudsman;1
```

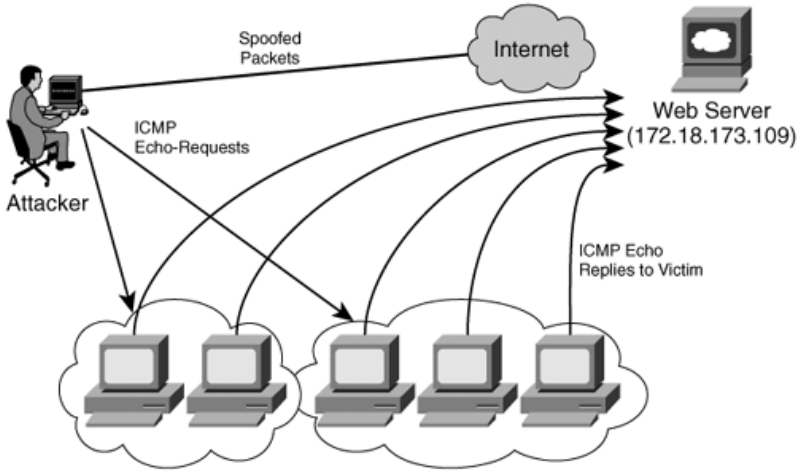
XSS-attack på valsedel.

Skydd mot Access attacks

- **Password attack**
  - Bra lösenordpolicy, utbilda personalen
- **Trust exploitation**
  - Användare ska inte ha onödiga rättigheter
  - Applikationer skall inte ha onödiga rättigheter
- **Man in the middle**
  - Lager-2-säkerhet (mer i kapitel 6)
- **Buffer overflow/XSS/SQL Injections**
  - Patcha!
- **Social engineering**
  - Utbilda personalen!

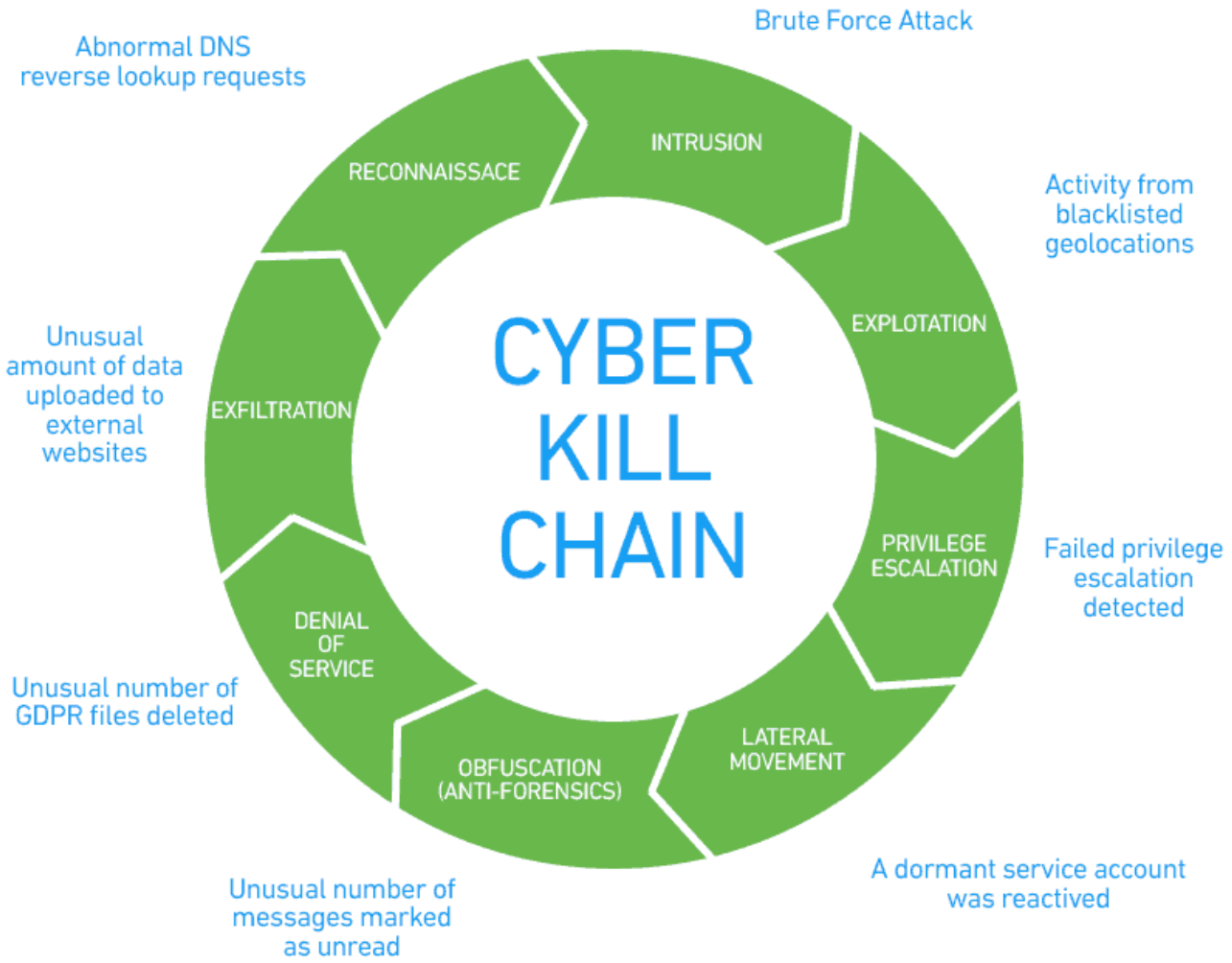
Denial of Service attacks

- **Syftet:** Sänka tillgängligheten för ett nätverk/tjänst/klient
- Ofta överbelastningsattacker
  - SYN flooding
  - Smurf attack
  - Ping flood
  - DDoS
  - …men inte alltid (Ping of death)



- **Motverka:**
  - Högre kapacitet än ”motståndaren” (ISP/Cloud)
  - Blockera så mycket trafik som möjligt innan det når CPU, t.ex. via accesslistor
  - Antispoofing-tekniker, t.ex. IP Source Guard
  - IDS/IPS

Cyber Kill Chain



https://www.exabeam.com/explainers/information-security/cyber-kill-chain-understanding-and-mitigating-advanced-threats/

Hur skyddar vi oss?

Riskhantering…

- …bör alltid vara första steget vid arbete med säkerhet. Kan även vara motiverat vid:
  - Förändringar i verksamheten (inkl. teknikinköp)
  - Krav från nya lagar (t.ex. GDPR), partners, kunder eller nya standarder på marknaden
- Här tar vi reda på vad som behöver skyddas, hur mycket och vilken typ av säkerhet som ska implementeras
- Det vi vill skydda är informationens CIA
- Vad är risk?

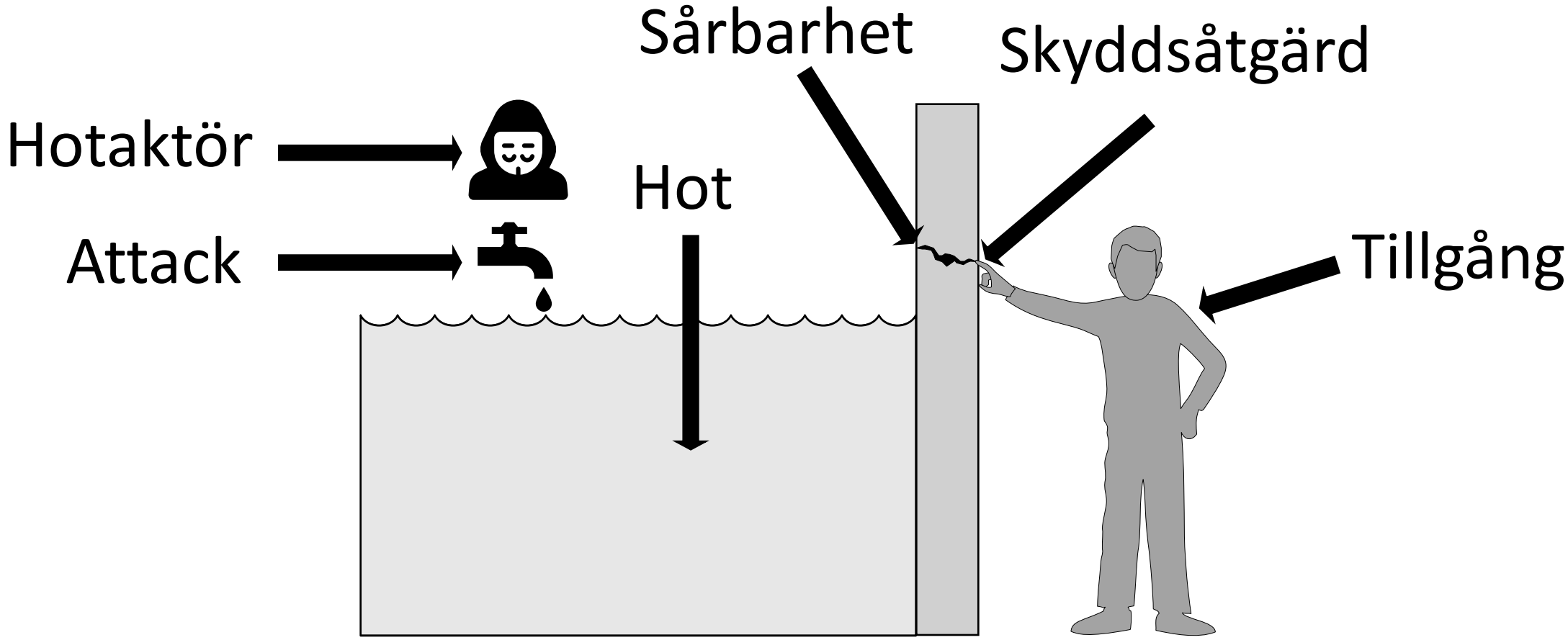
Risk = Hot * Sårbarhet

Sannolikheten att en viss hotfaktor utnyttjar en sårbarhet

Risk = (Hot * Sårbarhet) * Värde(Tillgång) – Åtgärder

Sannolikheten att en viss hotfaktor utnyttjar en sårbarhet i en tillgång, minus de skyddsåtgärder som implementeras

Riskhantering



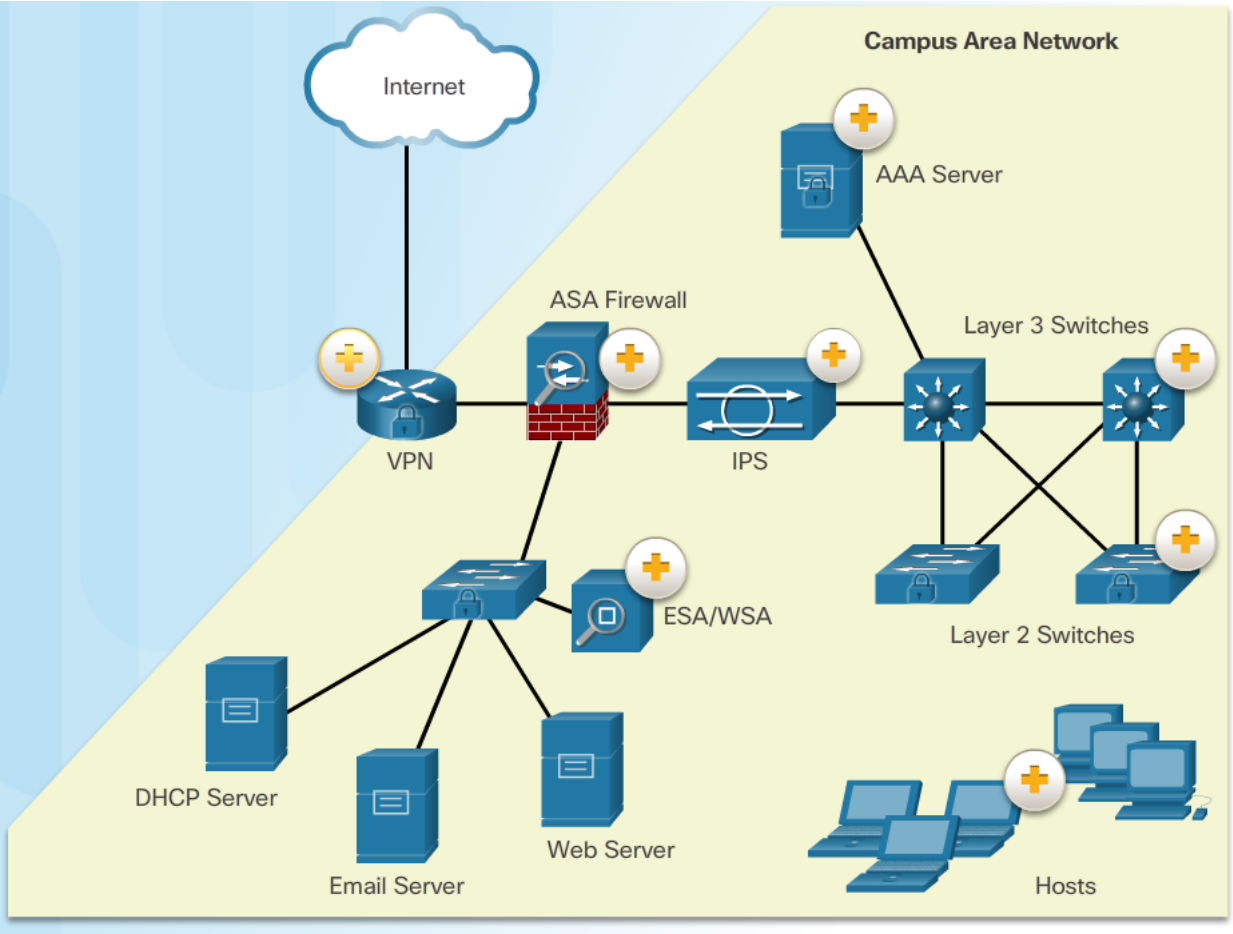
Pfleeger, C. P., Pfleeger, S. L., & Coles-Kemp, L. (2024). Security in computing (Fifth edition). Prentice Hall.

Åtgärder: Defense-in-depth

- Säkerhet på flera olika nivåer, t.ex.
  - **Administrativt**
    - Policys och utbildning
  - **Tekniskt**
    - Säkra HW/SW, OSI L1-7
  - **Fysiskt**
    - Säkra utsidan och insidan
    - HVAC och UPS
- Vad händer om vi har en stark teknisk lösning, men ingen säkerhetspolicy och icke-utbildad personal?

Defense-in-depth

- Skydd på flera olika nivåer
- Brandvägg (Firepower, FortiGate)
- VPN (Virtual Private Network)
- IPS (Intrusion Prevention System)
- ESA / WSA
- AAA



AAA

- **Authentication** – Vem är du?
  - Inloggning, grunden för all säkerhet. När man vet vem kan man bestämma rättigheter, logga osv
- **Authorization** – Vad får du göra?
  - När man vet VEM som är inloggad kan man bestämma VAD som får göras
    - Rättigheter i filsystem
    - Tillgängliga kommandon i Cisco IOS
- **Accounting** – Vad har du gjort?
  - När man vet VEM som är inloggad kan man logga VAD som har hänt
    - Även processer körs som en användare i t.ex. Windows Server

Att göra

- Läsanvisningar finns på Canvas (jag visar)
- Inspelningar för **kapitel 4-6 (Säkra nätverksenheter)** samt **kapitel 7 (AAA)** är publicerade på Canvas
- Dugga körs först nästa vecka
- Veckans laboration är (snart) publicerad i Canvas
  - För säkerhetsfunktioner använder vi främst 2901, 2811 är begränsade

kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering